

会计事务所资料收集系统——系统设计说明书

文档属性	内容
系统名称	Client Records / 会计事务所资料收集系统
文档版本	1.0
文档状态	最终交付版
基线日期	2026-09-25
适用对象	项目负责人、会计业务人员、研发、测试、运维及 AI 团队
设计范围	Web 前端、业务后端、异步 Worker、AI Agent、数据存储、容器部署和运维边界

1. 文档目的

本文是系统最终交付和项目汇报的总说明，回答以下问题：

1. 系统解决什么业务问题，已经交付哪些能力；
2. 用户、前端、后端、Worker、Agent 和数据存储如何协作；
3. 核心业务状态、数据、权限和接口如何设计；
4. AI 能做什么、不能做什么，真实模型如何接入；
5. 当前演示环境怎样部署、验证和恢复；
6. 哪些能力已经实现，哪些仍属于正式生产前待办。

本文描述当前交付基线，不用未来规划冒充已实现功能。阶段开发过程和详细 Agent 协议分别参见文末交付物索引。

2. 项目背景与目标

会计事务所在每月记账前，需要客户提交发票、收据、银行对账单和相关支持材料。传统流程主要依赖邮件、即时通信和人工表格，常见问题包括：

- 客户不知道还缺哪些材料；
- 文件期间、主体或内容错误，直到会计开始工作后才被发现；
- 客户经理需要反复催办并手工整理文件；
- 多轮补交缺少统一记录，审核责任和证据关系难以追溯；
- 资料准备时间不可见，延迟记账和财务关账。

本系统以“资料要求”为中心，把账户管理、请求创建、客户上传、多轮补交、审核、AI 辅助和审批记录放到同一条可审计流程中。

核心目标不是简单保存文件，而是持续推动每个资料项从“待提交”到“已满足”，最终由会计确认整单可以进入记账。



3. 交付范围与当前状态

3.1 已实现能力

领域	当前能力
身份认证	JWT 登录、access token 刷新、登出撤销、修改密码、邀请接受、密码重置
组织与账户	事务所员工、客户、客户联系人、角色、会计分配、客户银行账户
收集请求	创建、编辑草稿、复制历史请求、发布、取消、筛选、排序和分页
客户门户	查看请求、拖动上传、批量上传、文件预览、备注、移除草稿文件、提交和补交
文件处理	PDF/PNG/JPEG 校验、大小限制、SHA-256 去重、隔离区、ClamAV 扫描、受控下载
审核闭环	单项通过、退回、豁免，多轮补交，整单批准、撤回批准和关闭
证据与审计	显式 evidence 关系、不可变审核决定、活动记录、SYSTEM/USER actor 区分
AI 基线	上传快速分类、提交后完整审核、搜索动作、金额关系、自动退回和自动满足单项
前端体验	响应式布局、英文默认、简体中文、浅色/深色主题、统一筛选和状态展示
工程交付	前后端与 Agent 独立仓库和镜像、GitHub Actions、ECR、Docker Compose 部署

3.2 部分实现或待外部条件

能力	当前状态
真实 AI 模型	Agent 和协议已部署；尚无正式模型 URL、健康地址和密钥，生产 Provider 为 DISABLED
Email/飞书通知	Outbox 和去重已实现；记录固定为 SUPPRESSED/PROVIDER_DISABLED，不实际发送
HTTPS 与正式域名	当前演示环境仅开放 HTTP 80；正式使用前必须配置域名、证书和安全 Cookie
自动备份与恢复演练	已定义要求，尚未交付定时备份、异地副本和可验证恢复报告
监控告警	有健康检查和结构化日志基线；尚未接入集中日志、指标平台和告警渠道

3.3 明确不在本次范围

- 自定义流程设计器、拖拽审批节点和复杂模板市场；
- PostgreSQL RLS、独立消息中间件、Celery 和微服务拆分；
- S3/对象存储、CDN、多节点容灾和自动扩缩容；
- 向量数据库和模型训练平台；
- FastAPI 管理后台、SQLAdmin 和面向运维人员的低代码后台；
- 正式 Email、飞书、短信通知 Provider。

4. 需求追踪

业务问题	系统设计	验收表现
客户不知道缺什么	收集请求包含结构化 requirements	客户门户逐项显示必交材料和当前状态
文件经常不完整或错误	安全扫描、快速分类、 提交后主体/期间/金额审核	问题项显示明确原因并可退回补交
反复提醒耗时	Dashboard、截止日期、 状态筛选、通知 Outbox	会计可快速定位等待客户、 逾期和待审核请求
补交后历史混乱	每次提交生成独立 submission round	会计统一切换轮次，旧文件和决定仍可追溯
多文件关系复杂	requirement 与 document 多对多，保存 evidence relation	支持多发票对一笔付款、 历史发票和当前付款等场景
AI 结论不可控	Backend 校验 Agent 输出， 整单批准始终人工	非法 evidence、 低置信度或错误金额关系转人工

业务问题	系统设计	验收表现
多客户数据泄漏风险	firm/client 作用域授权和复合外键	猜测其他客户资源 ID 无法读取或关联
操作重复或并发冲突	Idempotency-Key、版本号和行锁	重复请求不产生重复事件，旧版本写入返回冲突

5. 用户与权限设计

5.1 固定角色

角色	主要职责
FIRM_ADMIN	管理事务所员工、客户、分配关系和全部请求；可撤回整单批准
ACCOUNTANT	管理被分配客户的收集请求、审核、退回、豁免、批准和关闭
CLIENT_ADMIN	查看所属客户请求、上传和提交资料，并管理本客户联系人
CLIENT_SUBMITTER	查看所属客户请求、上传、移除草稿资料和提交

5.2 权限矩阵

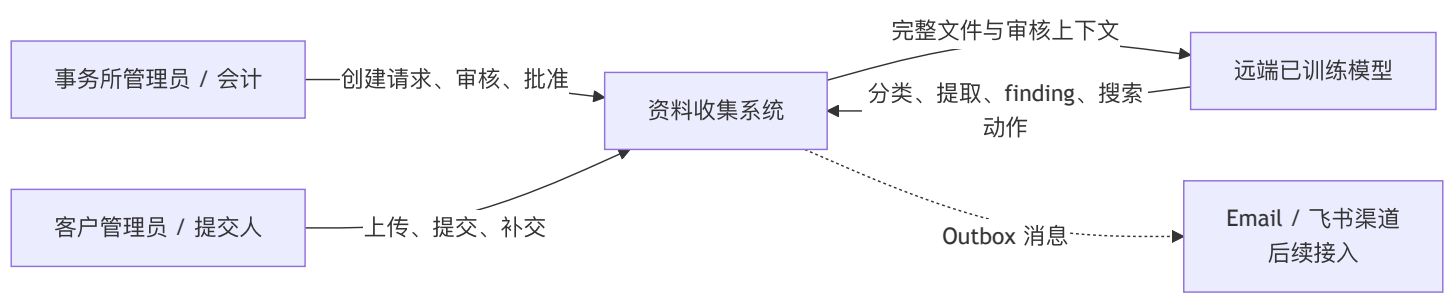
操作	事务所管理员	会计	客户管理员	客户提交人
管理事务所员工	✓	—	—	—
创建和维护客户	✓	查看已分配	查看所属客户	查看所属客户
分配会计	✓	—	—	—
管理客户联系人	✓	已分配客户	所属客户	—
创建、复制和发布请求	✓	已分配客户	—	—
上传、移除草稿和提交资料	—	—	✓	✓
查看客户公开反馈	✓	✓	✓	✓
单项审核和豁免	✓	已分配客户	—	—
整单批准	✓	已分配客户	—	—
撤回整单批准	✓	—	—	—
关闭已确认请求	✓	已分配客户	—	—

前端路由守卫仅用于改善体验。后端每次请求都根据 JWT 中的用户、事务所成员关系、客户成员关系或会计分配关系重新授权。

6. 设计原则与关键取舍

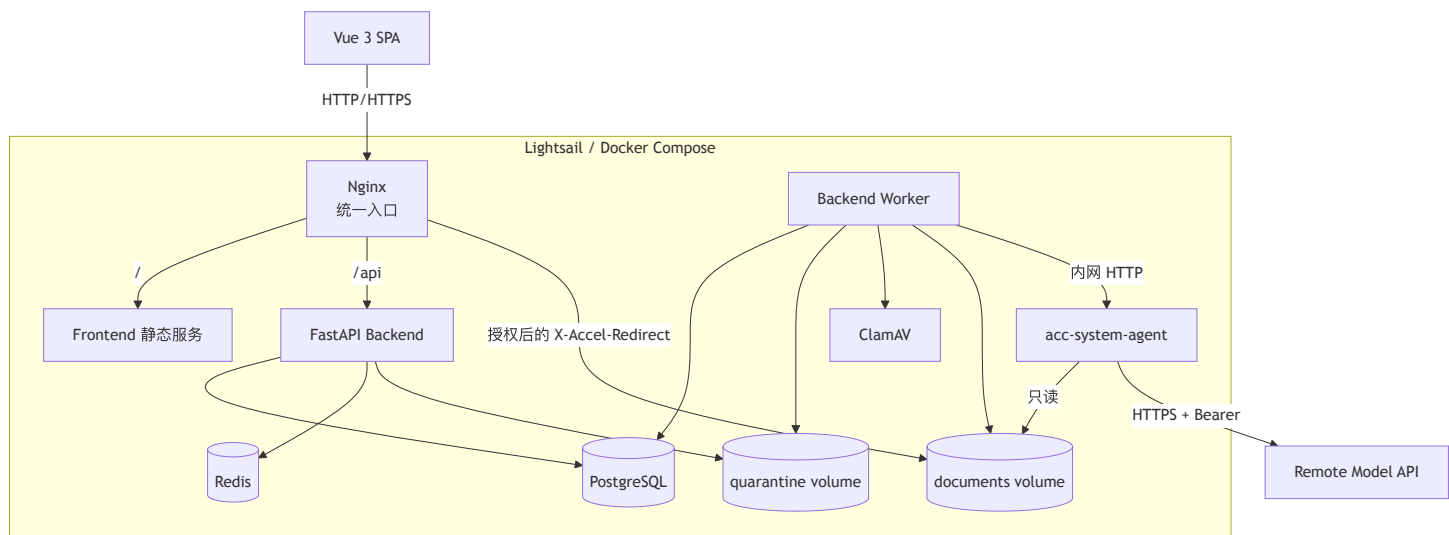
决策	采用方案	设计理由
应用形态	模块化单体 Backend + 独立 Agent	业务事务集中、部署简单，同时隔离模型与文件信任边界
事实源	PostgreSQL	状态迁移、审核决定、事件和 Outbox 可在同一事务提交
Redis 用途	会话撤销和限流等可重建状态	不把审批状态放入易失缓存
异步任务	数据库租约 Worker	当前单机规模无需额外消息中间件
工作流	固定状态机和业务动作 API	流程明确，不为暂不存在的自定义流程需求引入引擎
文件存储	Docker 持久卷	满足当前单机演示；容量和容灾成为瓶颈后再迁移 S3
AI 接入	独立只读 Agent + 远端模型 API	模型无权访问业务数据库，Backend 保持最终裁决权
通知	Transactional Outbox	状态和待发送记录原子提交，渠道失败不回滚业务
前后端命名	API snake_case，前端 camelCase	后端符合 Python 习惯，转换集中在 Axios 边界
前端状态	Pinia 仅保存认证和 UI 偏好	页面数据以服务端为准，避免第二套业务状态

7. 系统上下文



系统只负责“资料是否满足本次记账准备要求”，不执行总账记账、税务申报、付款或银行操作。

8. 总体技术架构



核心边界：

- 浏览器只能访问 Nginx；
- Backend 是唯一业务入口和状态机所有者；
- Worker 与 API 使用同一个后端镜像，但启动命令不同；
- Agent 没有 PostgreSQL、Redis、JWT 密钥和业务写权限；
- Nginx 只读挂载最终资料卷，不挂载隔离区；
- 模型故障不影响人工上传、审核和批准。

9. 组件设计

9.1 Vue 前端

职责：

- 事务所工作台、客户门户和账户页面；
- 表单校验、筛选、分页、排序和响应式交互；
- access JWT 内存管理及 refresh 协调；
- 上传进度、文件拖放、AI 分类确认和审核结果展示；
- 英文/简体中文、浅色/深色主题和移动端适配。

前端不决定权限和状态迁移，也不持久化服务端业务事实。

9.2 Nginx

职责：

- 统一 Web 入口；
- /api/ 反向代理至 Backend；

- 其他路径转发至 Frontend；
- 通过 internal location 提供已经授权的文件；
- 统一上传大小、代理超时和安全响应头。

9.3 FastAPI Backend

职责：

- 认证、租户授权和角色权限；
- 账户、客户、请求、资料项和提交轮次管理；
- 业务状态机、幂等、并发控制和审计；
- 文件元数据、受控下载和 Portal 数据隔离；
- AI run 编排、输出校验、自动单项决定和人工覆盖；
- Outbox 生成。

9.4 Backend Worker

职责：

- 隔离文件的异步安全扫描与落盘；
- 领取 CLASSIFY/REVIEW run；
- 调用 Agent、处理超时、重试和租约过期；
- 执行授权范围内的当前/历史资料搜索；
- 保存结构化 AI 输出并在事务内应用允许的自动决定。

任务使用数据库状态、`next_attempt_at`、`locked_by` 和 `locked_until` 实现租约；外部 HTTP 调用不占用长事务。

9.5 acc-system-agent

职责：

- 校验 `storage_key`、普通文件、MIME 文件头、大小和 SHA-256；
- 从只读卷读取完整 PDF/图片；
- 把文件转换为 Base64 后调用远端模型；
- 校验 CLASSIFY/REVIEW 的严格 schema；
- 返回稳定错误，不泄漏模型响应、文件内容或密钥。

Agent 不能搜索业务数据、修改状态、发送通知或批准整单。

9.6 PostgreSQL

保存账户、客户、收集请求、提交轮次、文件元数据、审核决定、事件、AI run、幂等记录和 Outbox。它是业务事实的唯一权威来源。

9.7 Redis

保存 refresh session/revocation 和限流等可重建状态。Redis 不保存收集请求和审核结论。

9.8 文件卷与 ClamAV

- 新文件先写入 quarantine；
- Worker 调用 ClamAV；
- 扫描通过后移动到 documents；
- 扫描完成前不能预览、下载或交给 Agent；
- 文件记录保存 SHA-256，重复内容可复用底层文件；
- 业务“删除”通过 link 排除实现，不直接删除审计历史。

10. 核心业务流程

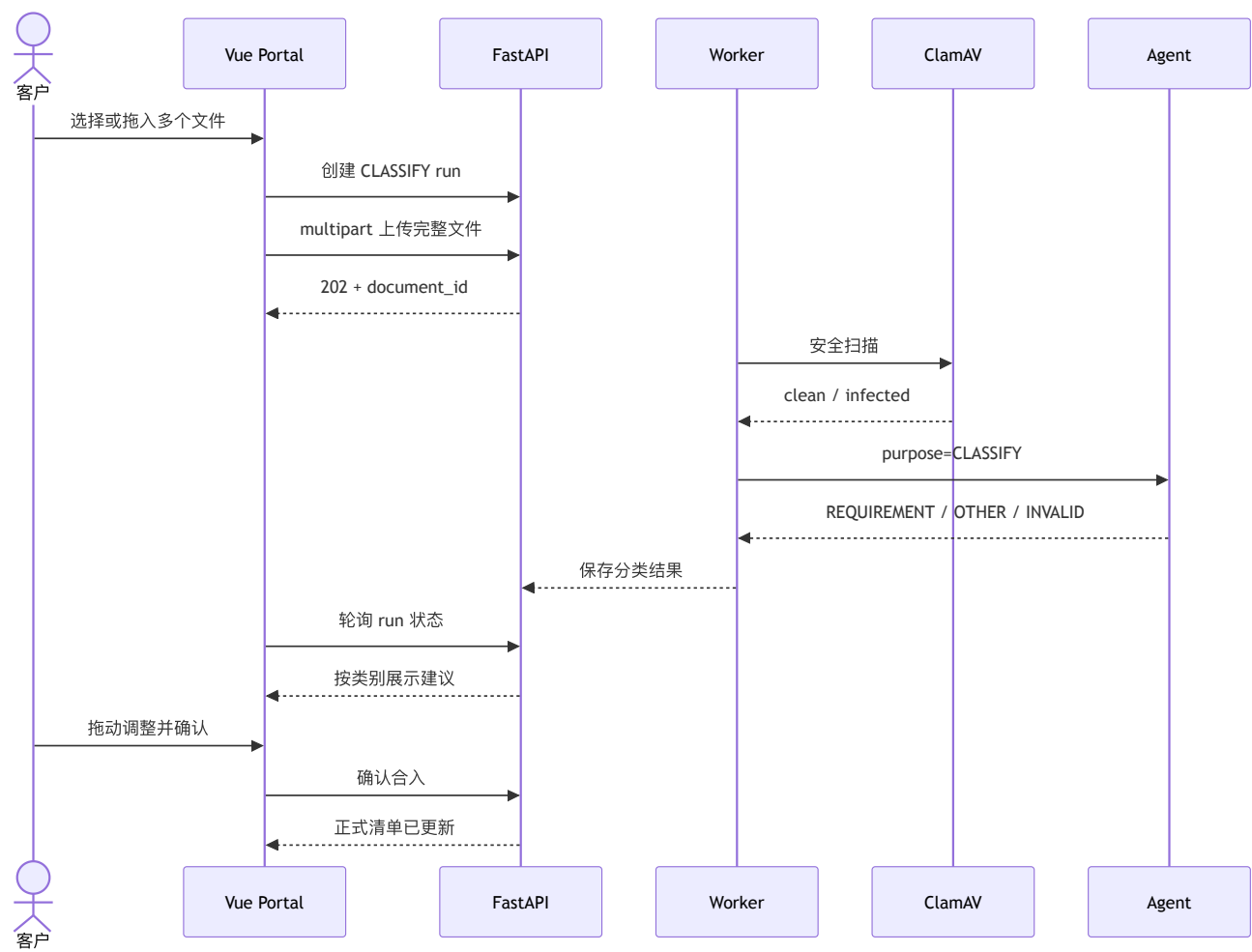
10.1 账户与客户建立

1. 事务所管理员创建客户并分配会计；
2. 事务所人员邀请第一个客户管理员；
3. 客户管理员接受邀请并可继续邀请客户提交人；
4. 邀请 token 只保存哈希、具有有效期且只能使用一次；
5. 最后一个有效客户管理员不能被移除或降级。

10.2 创建和发布收集请求

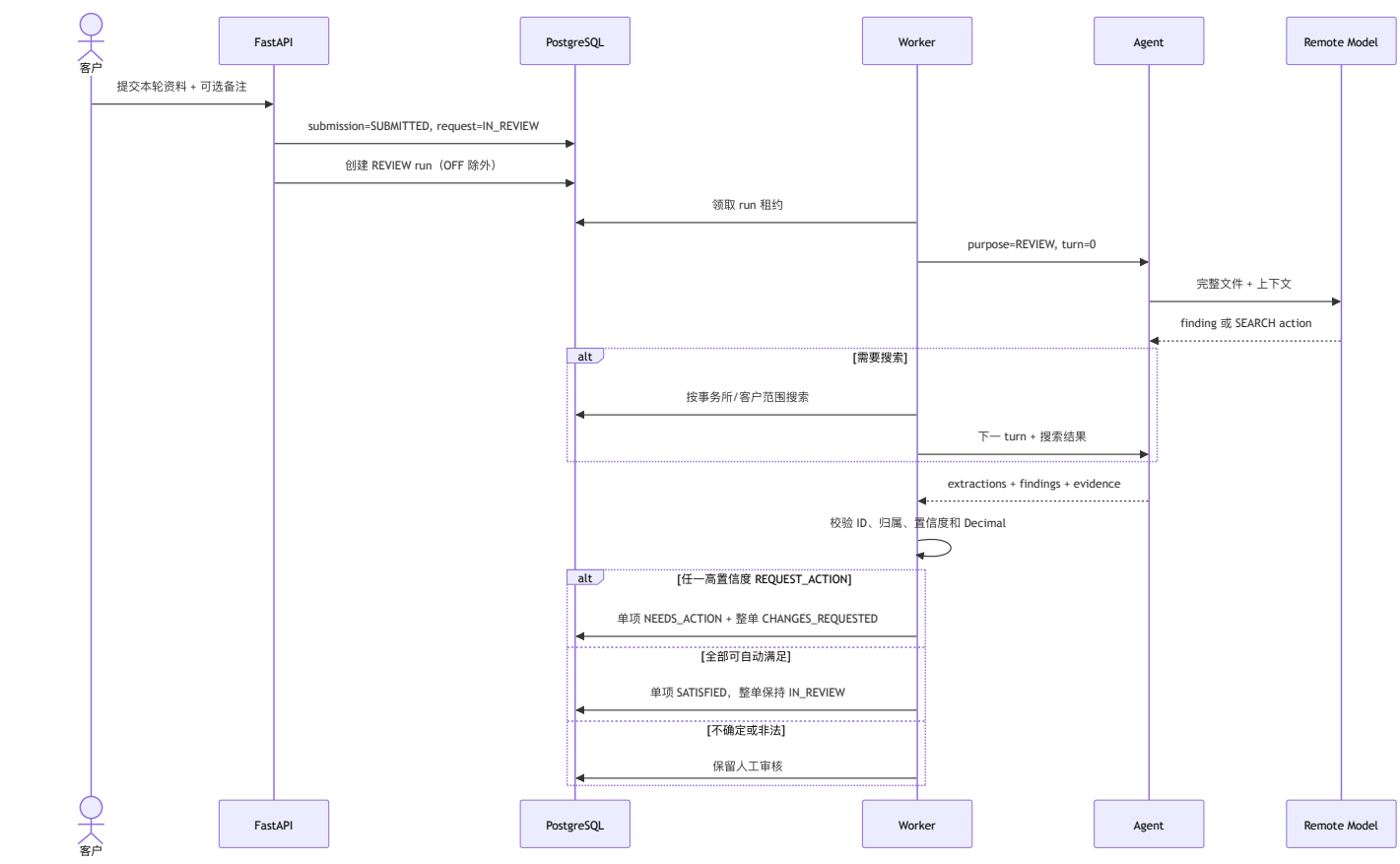
1. 会计选择客户、期间、截止日期和资料要求；
2. 系统根据资料类型设置内部 `analysis_type`，用户不手工选择；
3. 会计选择 AI 模式和自动处理偏好；
4. 草稿可继续编辑或复制历史请求；
5. 发布后请求进入 `OPEN`，资料要求不再物理删除；
6. 同一客户和期间只允许一个未取消请求。

10.3 上传与快速分类



分类确认前，文件不进入正式资料清单。分类阶段只返回类别、资料类型、目标资料项和置信度，不执行主体、期间、金额或审核判断。

10.4 客户提交与 AI 审核

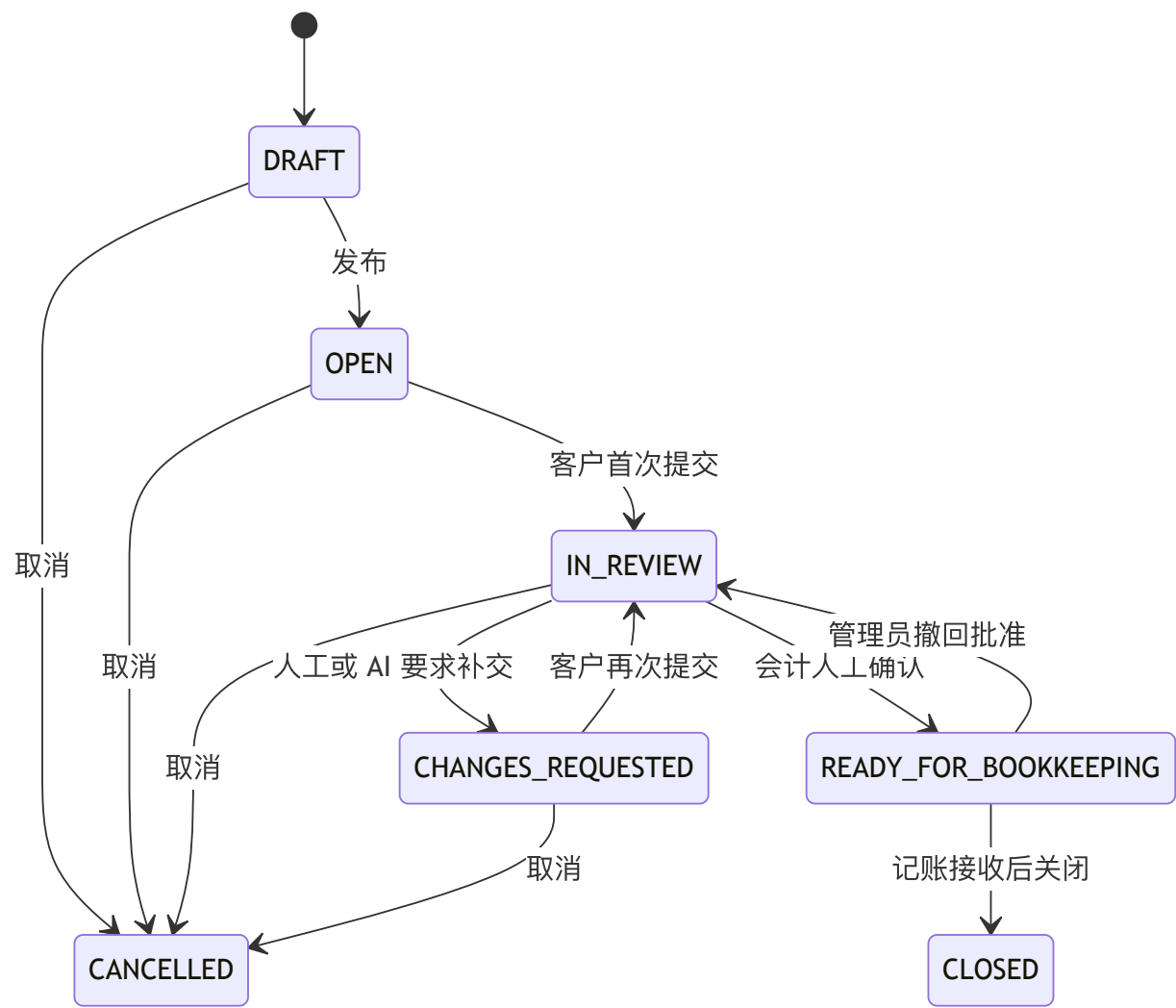


10.5 会计审核与整单确认

- 1. 会计按 submission round 切换本轮文件；
- 2. 页面展示文件预览、客户整体备注、提取字段、AI finding 和 evidence；
- 3. 会计可以一键把 AI 建议填入审核表单，再手工修改；
- 4. 保存人工决定时必须显式选择 evidence；
- 5. 任一资料项未完成审核时，不能要求补交或批准下一步；
- 6. WAIVE 必须由会计填写理由；
- 7. 全部必交项为 SATISFIED/WAIVED 后，会计才可确认整单；
- 8. AI 永远不能执行整单批准。

11. 状态机设计

11.1 收集请求状态



对外显示：

内部状态	主要显示文本
DRAFT	草稿
OPEN	待客户提交
IN_REVIEW 且 AI 未全部完成	审核中
IN_REVIEW 且本轮 AI 全部通过	待人工确认
CHANGES_REQUESTED	待客户补交
READY_FOR_BOOKKEEPING	已确认
CLOSED	已关闭

内部状态	主要显示文本
CANCELLED	已取消

11.2 资料项状态

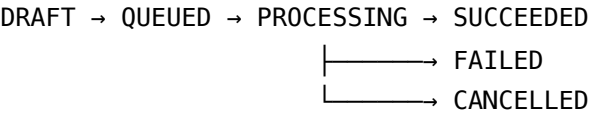
状态	含义
PENDING	尚未收到可审核资料
RECEIVED	已收到，等待审核
NEEDS_ACTION	有问题，等待客户补交或说明
SATISFIED	已满足
WAIVED	会计明确豁免

问题原因使用独立
issue_code： MISSING 、 WRONG_PERIOD 、 ENTITY_MISMATCH 、 UNREADABLE 、 INCOMPLETE 、 OTHER 。

11.3 文件状态

QUARANTINED → AVAILABLE
QUARANTINED → FAILED
QUARANTINED → EXCLUDED
AVAILABLE → EXCLUDED（通过关联记录逻辑排除）

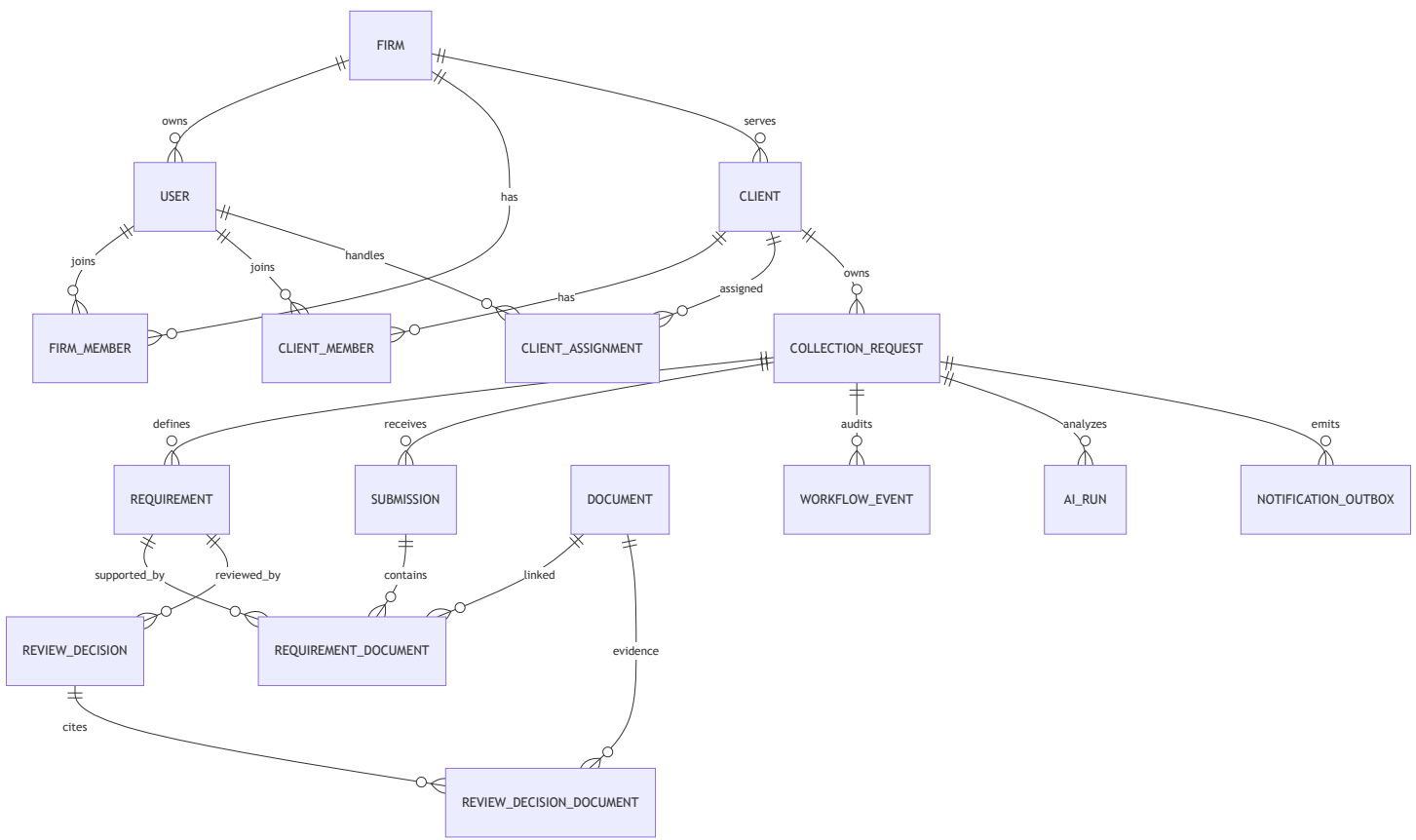
11.4 AI run 状态



分类 run 使用 confirmed_at 和 confirmation 独立记录用户是否合入，避免把“模型成功”和“用户接受结果”混为同一状态。

12. 数据架构

12.1 核心实体关系



12.2 表分组

分组	表
身份与权限	firms , users , firm_members , client_members , client_assignments
客户基础资料	clients , client_bank_accounts , user_invites , password_reset_tokens
收集流程	collection_requests , requirements , submissions
文件与证据	documents , requirement_documents , review_decision_documents
审核与审计	review_decisions , workflow_events , audit_events
异步与可靠性	ai_runs , notification_outbox , idempotency_records

12.3 关键约束

- 所有业务实体直接或间接受 `firm_id` 约束；
- 子表通过复合外键阻止跨事务所关系，而非只依赖代码过滤；

- 同一客户、期间最多一个未取消请求；
- 同一请求、轮次号唯一，且同一时间最多一个 DRAFT submission；
- review_decisions 和工作流事件只追加，不覆盖历史；
- 同一 ai_run + requirement 最多一条 AI 自动决定；
- Outbox dedupe_key 唯一；
- 月度期间存当月第一天，时间戳统一存 UTC；
- 金额关系通过十进制字符串传输，由 Backend 使用 Decimal 重算。

12.4 多轮提交模型

补交不会覆盖旧文件。每次客户提交形成一个新的 submission.round_no，新一轮默认继承仍有效的历史资料关联；客户可以在可编辑状态下排除旧文件并追加新文件。会计审核页一次只查看一个轮次，避免把所有轮次堆叠成无法理解的文件列表。

13. API 与接口设计

13.1 通用约定

- 业务 API 前缀： /api/v1 ；
- 请求和响应字段： snake_case ；
- 前端通过 Axios 边界转换为 camelCase ；
- 错误结构： { code, message, details, request_id } ；
- 列表使用服务端分页、排序和过滤；
- 状态迁移使用动作端点，不开放任意状态字段修改；
- 关键写操作携带 Idempotency-Key ；
- 可并发编辑实体携带 version，旧版本返回 409 。

13.2 API 分组

分组	代表端点
认证	POST /auth/login， /auth/refresh， /auth/logout， GET /me
邀请和密码	/auth/invitations/accept， /auth/password-reset/*， /me/password
员工与客户	/users， /clients， /clients/{id}/members， /assignments， /bank-accounts
收集请求	/collection-requests， /{id}/publish， /{id}/copy， /{id}/cancel， /{id}/events
客户门户	/portal/collection-requests， /documents， /document-links， /{id}/submit
上传分类	/portal/collection-requests/{id}/classification-runs/*

分组	代表端点
审核	/requirements/{id}/review , /{id}/request-changes , /{id}/approve , /{id}/reopen , /{id}/close
AI 审核查询	/collection-requests/{id}/review-runs , /{run_id}/retry
文件下载	员工 /documents/{id}/download ; 客户 /portal/document-links/{id}/download
健康检查	/health/live , /health/ready

13.3 Backend-Agent 接口

```
POST /v1/analyze
Content-Type: application/json
Idempotency-Key: <run_id>:<turn>
```

purpose 为 CLASSIFY | REVIEW。Backend 发送 document_id、storage_key、content_type 和 sha256；Agent 在只读卷读取文件。远端模型只接收 Base64 完整文件，不接收本地路径。

严格字段、枚举和示例见 [AI Agent 接口与架构交接](#)。

13.4 通知 Provider 接口

首版只定义最小边界：

```
send(recipient: str, template: str, payload: dict) -> None
```

业务事务只写 Outbox。渠道 Worker 以后消费 Outbox，不允许由页面请求直接调用 Email/飞书并决定业务提交是否成功。

14. 前端设计

14.1 技术栈

- Vue 3 + TypeScript + Vite；
- Vue Router + Pinia；
- shadcn-vue / reka-ui + Tailwind CSS；
- Axios + axios-case-converter；
- Vue l18n；
- Vitest + ESLint + vue-tsc。

14.2 页面结构

```
/login
/invitations/accept

/staff
  /profile
  /collections
  /collections/new
  /collections/:id
  /collections/:id/edit
  /collections/:id/review
  /clients
  /clients/:id
  /admin/users

/client
  /profile
  /collections
  /collections/:id
  /contacts
```

14.3 状态归属

状态	归属
access JWT、当前用户	Pinia auth，内存
主题、侧栏、语言偏好	Pinia/UI 与本地非敏感偏好
列表筛选、分页、排序	URL query
请求详情和审核数据	页面查询，服务端为准
权限和状态迁移	Backend

14.4 交互原则

- 使用业务动作名称，不让用户直接编辑状态；
- 会计审核采用资料项、预览、决定三栏布局；
- 活动记录统一放在请求详情，不在审核页重复一套；
- 文件列表按轮次切换，客户备注按整轮展示；
- 破坏性操作、豁免和最终批准使用 Dialog 确认；
- 搜索即时生效，不要求额外 Apply；
- 小屏布局减少表格列并改为信息卡，不强行压缩桌面表格；

- 状态同时使用文字和图标，不能只靠颜色。

14.5 视觉和国际化

界面采用 iOS 风格的信息层级、留白、圆角和适度半透明效果，但不牺牲表格密度和会计业务可读性。所有卡片、筛选器和状态控件使用统一设计 token。

英文是默认 locale 和 fallback；简体中文可由用户主动选择。API 枚举和错误 code 保持稳定英文值，前端映射为本地化文本。日期、数字和币种通过 Intl /Vue I18n 格式化。

15. 后端设计

15.1 技术栈

- Python 3.12；
- uv；
- FastAPI + Pydantic；
- SQLAlchemy 2 + Alembic；
- PostgreSQL；
- Redis；
- PyJWT；
- Argon2 密码哈希；
- pytest。

15.2 模块边界

app/api/auth.py	认证和会话
app/api/accounts.py	员工、客户、联系人、邀请和分配
app/api/collections.py	请求、资料项、列表和事件
app/api/portal.py	客户上传、文件和提交
app/api/classification.py	CLASSIFY run
app/api/review.py	审核、审批和 REVIEW run 查询
app/worker.py	文件安全处理和任务轮询
app/review_analysis.py	REVIEW 编排、搜索和自动决定
app/models.py	业务数据模型与数据库约束

15.3 事务与一致性

状态迁移统一执行：

1. 按租户加载并锁定请求；
2. 校验角色、分配关系、当前状态和 version；
3. 更新当前快照；

- 4. 追加审核决定或事件；
- 5. 必要时写 Outbox；
- 6. 同一事务提交。

幂等记录保存 actor、key、路径、请求哈希和响应。相同 key、相同请求返回原结果；相同 key、不同请求返回冲突。

15.4 Worker 可靠性

- FOR UPDATE SKIP LOCKED 领取任务；
- 租约过期可被其他 Worker 重领；
- 外部调用在事务外执行；
- 结果回写前重新检查 lease、请求状态和 submission；
- 迟到结果不能覆盖新一轮次；
- Agent 不可用最多有限重试，最终转人工而非破坏业务状态。

16. AI 设计

16.1 两阶段策略

阶段	触发时机	允许输出	禁止事项
CLASSIFY	文件上传并安全扫描后	类别、资料类型、目标资料项、置信度	主体/期间/金额审核、搜索和状态修改
REVIEW	客户正式提交后	提取字段、finding、evidence、金额关系、搜索动作	直接访问数据库、豁免、整单批准和通知发送

16.2 AI 模式

模式	行为
OFF	不创建提交后 REVIEW run
SUGGEST	保存并展示分析，始终由会计决定
AUTO_REVIEW	通过 Backend 校验并达到请求阈值后，可自动满足或退回单项

新请求默认 AUTO_REVIEW，满足和退回阈值均为 0.980。前端以“更偏自动 / 平衡处理 / 更偏人工”等文字选项呈现，不让普通用户直接理解抽象小数。

16.3 自动执行边界

只有同时满足以下条件，Backend 才自动应用 finding：

- 请求为 AUTO_REVIEW ；
- 建议是 SATISFY 或 REQUEST_ACTION ；
- confidence 达到该请求对应阈值；
- evidence 属于同事务所、同客户和有效提交；
- 所有 ID、枚举和 schema 合法；
- 金额关系通过 Backend Decimal 重算；
- 当前资料项仍处于可应用状态；
- finding 不是 ESCALATE 。

任一自动 REQUEST_ACTION 会把整单退回客户。全部单项自动通过时，整单保持 IN_REVIEW 并显示“待人工确认”。

16.4 可解释性与人工覆盖

会计侧展示：

- 模型提取字段；
- 主体和期间检查；
- 当前和历史 evidence 及关系；
- 金额 operands、运算和差额；
- 转人工原因；
- AI 自动决定标识。

人工决定会追加新记录并成为当前结论，AI 和旧人工记录继续保留。客户侧只显示公开状态和 client_message ，不返回模型原始输出、置信度、内部备注和搜索轨迹。

16.5 当前上线状态

Agent 容器和接口已经部署， /health/live 正常。因为没有正式模型接口，生产环境：

```
AGENT_CLASSIFICATION_PROVIDER=DISABLED
AGENT_REVIEW_PROVIDER=DISABLED
MODEL_API_URL=
MODEL_HEALTH_URL=
MODEL_API_KEY=
```

因此当前线上可完整使用人工流程，但不能把开发环境的固定 Mock 案例视为真实 AI 能力。

17. 安全与隐私设计

17.1 认证与会话

- 密码使用 Argon2 哈希；
- access JWT 只保存在前端内存，通过 Bearer header 发送；
- refresh JWT 使用 HttpOnly Cookie；
- refresh token 轮换并检测重放；
- 修改密码和登出会撤销相应会话；
- 登录、邀请和密码重置接口限流；
- 生产 HTTPS 下必须启用 Secure Cookie。

17.2 租户与授权

- 后端不接受请求参数提供 `firm_id`；
- 从已验证 Principal 取得事务所；
- 员工按事务所角色和客户分配授权；
- 客户按 `client_members` 授权；
- 不可见资源优先返回 404，减少 ID 枚举；
- 数据库复合外键阻止跨事务所关联。

17.3 文件安全

- 只允许 PDF、PNG、JPEG；
- 同时检查扩展名、声明 MIME 和文件头；
- 单文件默认最大 25 MiB；
- 新文件先进入不可下载隔离区；
- 生产环境必须经 ClamAV 扫描；
- 文件名只作为展示值，storage key 由服务端生成；
- 下载先授权，再通过 Nginx internal location 返回；
- Content-Disposition 和 nosniff 防止浏览器执行不可信内容；
- Agent 使用目录描述符和 `O_NOFOLLOW` 防止路径穿越和符号链接攻击。

17.4 密钥与日志

- 数据库密码、JWT secret、AWS 凭据和模型密钥不进入 Git 或镜像；
- GitHub Actions 通过 OIDC 获取 AWS 临时凭证；
- 应用日志不得记录密码、JWT、Cookie、文件正文、Base64 或模型原始敏感响应；
- 错误响应使用稳定 code，不回显供应商内部错误。

17.5 当前安全缺口

演示环境仍使用 HTTP 和公网 IP，不适合承载真实客户财务资料。正式上线前必须至少完成域名和 TLS、`COOKIE_SECURE=true`、备份加密、最小化 SSH 来源、集中日志、漏洞扫描和权限复核。

18. 部署与发布设计

18.1 仓库

仓库	职责
acc-system-frontend	Vue SPA、组件、路由、i18n 和前端测试
acc-system-backend	API、Worker、迁移、Compose 和 Nginx 配置
acc-system-agent	只读 AI 适配层和严格协议校验
acc-system-docs	业务、架构、开发、Agent 接口和交付文档

18.2 镜像和服务

服务	镜像
frontend	ECR acc-system-frontend:<git-sha>
backend / worker / migrate	ECR acc-system-backend:<git-sha>
nginx	ECR acc-system-nginx:<git-sha>
agent	ECR acc-system-agent:<git-sha>
postgres	官方 postgres:17.6-alpine
redis	官方 redis:8.2.1-alpine
clamav	官方 clamav/clamav:1.4

数据库和 Redis 已经是独立镜像，不为“自建镜像”复制一份内容相同的 Dockerfile。

18.3 CI/CD



GitHub Actions 负责测试、构建和推送 ECR，不直接 SSH 生产服务器。服务器 `.env.prod` 固定 SHA 标签，避免 `latest` 造成不可复现发布。

18.4 当前演示部署

项目	当前值
主机	AWS Lightsail Ubuntu, Singapore ap-southeast-1
入口	http://13.213.135.223
对外端口	80; 22 仅固定 CIDR 和 lightsail-connect
Compose 服务	nginx、frontend、backend、worker、agent、postgres、redis、clamav
数据库 revision	0010_classification_confirmation
Frontend image	d63d19889fa5fbf1bc1d7f6ae73a465aac019f1f
Backend image	49c5db2c94ab71d151ee983c2c6ad9d9a83b07e4
Agent runtime image	94314111e1d01d3b1451e258bbc862c3a3519813
Backend readiness	PostgreSQL、Redis 均为 ok
Agent readiness	live 正常；真实模型未配置，因此 ready 为 MODEL_NOT_CONFIGURED

18.5 发布与回滚

标准发布：

```
docker compose --env-file .env.prod pull
docker compose --env-file .env.prod run --rm migrate
docker compose --env-file .env.prod up -d --remove-orphans
```

应用回滚通过恢复 .env.prod 中上一组不可变镜像 SHA 并重新启动完成。数据库迁移回滚不能仅依赖应用镜像；破坏性迁移前必须备份，并优先使用向后兼容的扩展迁移。

19. 可用性、运维与恢复

19.1 健康检查

服务	检查
Backend live	进程是否运行
Backend ready	PostgreSQL 和 Redis 是否可用
Agent live	Agent 进程和版本

服务	检查
Agent ready	资料卷和远端模型是否可用
PostgreSQL	pg_isready
Redis	认证后的 PING
Nginx	首页可访问

Backend readiness 不依赖 Agent，从而保证模型故障时人工业务仍在线。

19.2 日志与审计

- 应用日志使用 request_id 串联请求；
- 业务审计记录 actor、事务所、资源和事件；
- workflow 活动记录向用户展示关键状态变化；
- AI run 保存模型版本、状态、错误类型和规范化输出；
- 日志与数据库审计职责分离，日志不是业务事实源。

19.3 正式生产建议

以下属于正式上线前必须完成的运维项：

- PostgreSQL 每日备份和定期恢复演练；
- documents 卷加密快照和异地备份；
- 磁盘容量、API 错误、Worker 积压、AI 连续失败和备份失败告警；
- 证书自动续期；
- 明确并批准 RPO/RTO。建议初始目标为 RPO 24 小时、RTO 4 小时，但这不是当前已验证承诺；
- 制定财务资料保留期限和客户删除请求处理规则。

20. 性能与扩展性

20.1 当前硬限制

项目	限制
单文件	默认 25 MiB
分类/审核单批文件数	最多 100
单次 Agent 文件总量	最多 100 MiB
Agent 响应	最多 1 MiB

项目	限制
REVIEW 搜索	最多 3 轮
单轮搜索追加	最多 20 个文件，并受 100 文件总量限制
模型连接超时	默认 10 秒
模型单轮推理超时	默认 180 秒

20.2 扩展路径

当前单节点 Compose 适合演示、小型事务所和早期验证，但尚未做负载测试，不能给出已验证并发容量。

达到以下信号时再演进：

信号	演进方案
文件卷容量或备份成为瓶颈	迁移 S3，对 Agent 使用受控对象读取
Worker 队列持续积压	增加 Worker 副本，再评估消息队列
单机故障不可接受	托管 PostgreSQL/Redis、对象存储和多实例应用
历史搜索规模显著增加	增加专用检索索引；有证据后再评估向量搜索
多服务直接访问数据库	引入更严格服务边界和 PostgreSQL RLS
通知量增加	独立 Outbox 消费者和渠道级幂等

21. 测试与验收

21.1 自动检查基线

子系统	结果	覆盖重点
Frontend	49 tests passed；ESLint、类型检查和 production build 通过	路由、认证、字段转换、账户、列表、Portal、审核和 AI 展示
Backend	发布基线 56 tests passed	JWT、租户隔离、并发、文件、提交、审核、搜索、自动决定和 Outbox
Agent	33 tests passed	文件边界、分类、审核 schema、幂等、远端错误、金额和搜索动作

Backend 集成测试有主动安全保护：只允许 `ENVIRONMENT=test` 、数据库名 `acc_test` 和 Redis DB 15，防止误删开发或生产数据。

21.2 关键验收场景

1. 管理员、会计、客户管理员和提交人的权限符合矩阵；
2. 猜测其他事务所或客户 ID 不能读取数据；
3. 会计创建、复制、发布和取消请求；取消后可为相同期间重建；
4. 客户拖动上传多个文件，确认分类前正式清单不变；
5. 扫描失败、分类失败或模型不可用时可转手动流程；
6. 客户提交带整体备注的第一轮资料；
7. G02 错期间和 G03 错主体产生明确补交原因；
8. B01 多发票合计和 B03 历史资料搜索保留完整 evidence；
9. F04 外币/手续费和 F05 进度款/保留款由 Backend 重算金额；
10. AI 自动退回问题轮次，全部通过时只进入“待人工确认”；
11. 会计可覆盖 AI 单项决定，但不能在必交项未完成时批准；
12. 客户补交只追加新轮次，旧文件和决定不消失；
13. 重复提交、Worker 重试和迟到结果不产生重复决定；
14. 客户 API 不返回内部备注、storage key、AI 原始输出和搜索轨迹；
15. Agent 停止后人工闭环仍可完成。

21.3 尚未完成的质量验证

- 真实模型准确率、召回率、置信度校准和财务专业评估；
- 正式性能、压力和长时间稳定性测试；
- 独立渗透测试、依赖漏洞门禁和恶意文件专项测试；
- 备份恢复、主机故障和磁盘耗尽演练；
- Email/飞书真实渠道验收；
- HTTPS 正式环境验收。

22. 风险与应对

风险	影响	当前控制	后续措施
模型误判	错误退回或错误满足资料项	双阈值、evidence、Decimal 重算、人工整单确认	真实数据评估、阈值校准、持续抽检
模型不可用	AI 分类/审核延迟	Provider 可关闭，人工流程独立	模型 SLA、超时监控和降级告警
单机故障	整体服务暂时不可用	持久卷、不可变镜像	托管数据库、对象存储、备份恢复
本地文件丢失	财务资料不可恢复	命名卷	加密快照、异地备份和恢复演练

风险	影响	当前控制	后续措施
HTTP 演示入口	财务资料传输风险	仅作为演示环境	正式域名、TLS 和 Secure Cookie
通知未投递	客户不能及时得知补交	页面状态为权威、Outbox 可追踪	接入 SES/飞书并监控失败
多租户越权	严重数据泄漏	后端授权、复合外键、隔离测试	安全审计和定期权限回归
长耗时文件/模型	Worker 积压	租约、超时、有限重试	指标告警、Worker 扩容、容量规划
财务数据保留不明确	合规与存储风险	不自动物理删除历史	与业务方确定留存和删除政策

23. 汇报指标建议

系统没有伪造上线前的业务收益数据。正式试运行后建议按事务所、客户和月份统计：

- 首次提交完整率；
- 每个请求的平均补交轮次；
- 从发布到首次提交的时间；
- 从首次提交到“已确认”的时间；
- 逾期请求比例；
- AI 自动退回率和自动满足率；
- AI 决定被人工覆盖的比例；
- 错误退回率和错误满足率；
- 模型失败、超时和人工降级比例；
- 会计处理每个请求的平均操作时长。

这些指标可以用于证明系统是否真正减少追踪成本、缩短资料准备周期，而不能只用“上传文件数”衡量价值。

24. 最终交付清单

24.1 代码与部署

- acc-system-frontend：Vue 前端、Dockerfile、Lint/Test/Build Action；
- acc-system-backend：FastAPI、Worker、Alembic、Dockerfile、Compose、Nginx 和 ECR Action；
- acc-system-agent：Agent 服务、严格协议、Dockerfile 和 ECR Action；
- AWS ECR：前端、后端、Nginx、Agent 镜像；
- AWS Lightsail：Compose 演示环境；
- PostgreSQL revision：0010_classification_confirmation。

24.2 文档

- [业务参考说明](#)；
- [系统架构设计](#)；
- [后端开发文档](#)；
- [前端开发文档](#)；
- [Agent 开发文档](#)；
- [AI Agent 接口与架构交接](#)；
- 本系统设计说明书。

25. 结论

本次交付已经形成可运行的会计资料收集闭环：事务所管理账户和客户，会计创建请求，客户上传并多轮补交，会计或受控 AI 审核单项，最终由会计确认整单。系统通过清晰状态机、租户隔离、显式 evidence、不可变审计记录和人工最终批准，保证自动化不会绕过业务责任边界。

当前最重要的后续工作不是继续增加页面，而是完成正式模型联调、HTTPS、备份恢复、监警告警和真实业务试运行。完成这些生产化工作后，系统才适合承载真实客户财务资料并用实际指标评估业务收益。

附录 A：核心术语

术语	含义
Collection Request	某客户、某期间的一次资料收集任务
Requirement	收集任务中的一个资料要求
Submission	客户一次正式提交或补交轮次
Document	物理文件及其安全、哈希和提取元数据
Evidence	审核决定引用的文件及 SUPPORTS/CONTRADICTS/REFERENCE 关系
Review Decision	对一个资料项的 SATISFY/REQUEST_ACTION/WAIVE 决定
AI Run	一次 CLASSIFY 或 REVIEW 异步分析任务
Outbox	与业务事务同时创建、等待外部渠道消费的通知记录
READY_FOR_BOOKKEEPING	所有必交项完成并由会计人工确认后的整单状态，界面显示“已确认”

附录 B：版本基线

仓库	交付基线
Frontend	d63d198
Backend	49c5db2
Agent runtime	9431411 ； 后续 839263e 仅更新说明文字
Docs	本文生成前基线 b6bfe0a